API SECURITY RISK ANALYSIS REPORT

Project: SmartShield Cybersecurity Suite
Author: Allan Naibei
Assessment Type: Passive API Security Analysis

---

1. Executive Summary

This report presents a security analysis of a publicly accessible API to identify potential risks related to **unauthorized access, data exposure, and request handling weaknesses**.

The assessment combined **API testing using Postman** and **network traffic analysis using Wireshark** to simulate real-world usage and observe how data is transmitted and controlled.

Key findings indicate that while the API ensures secure transmission through HTTPS, it lacks essential security controls such as authentication and rate limiting, which could expose it to misuse in a production environment.

---

2. Scope of Assessment

- **Target API:** JSONPlaceholder (public test API)
- **Assessment Type:** Passive (non-intrusive testing)
- **Tools Used:**
  - Postman
  - Wireshark
  - Browser Developer Tools

---

3. Methodology

The assessment followed a structured approach:

1. **Endpoint Testing**
   - Sent GET and POST requests to API endpoints
   - Observed responses and data returned
2. **Traffic Capture**
   - Captured live API traffic using Wireshark
   - Filtered and analyzed request/response behavior
3. **Security Review**

    - Checked for authentication mechanisms
    - Evaluated data exposure levels
    - Tested for rate limiting and input validation
4. **Risk Classification**
    - Categorized findings into Low, Medium, and High risk

---

4. Key Findings Overview

Vulnerability	Risk Level
Missing Authentication	High
Excessive Data Exposure	Medium
No Rate Limiting	Medium
Weak Input Validation	Low
Secure Transmission (HTTPS)	Positive

---

5. Detailed Findings

5.1 Missing Authentication (High Risk)

Observation:
API endpoints were accessible without any authentication mechanism such as API keys or tokens.

Evidence:

- No `Authorization` headers observed in requests
- API responded successfully to all unauthenticated requests

Impact:
Unauthorized users can access and interact with API data, increasing the risk of data misuse and unauthorized operations.

Business Explanation:
Without access control, any external party can retrieve or manipulate data, which could lead to data breaches or system abuse.

Recommendation:

- Implement API authentication (API keys, OAuth tokens)

- Enforce access control policies

5.2 Excessive Data Exposure (Medium Risk)

Observation:
API responses returned full datasets, including unnecessary user information.

Evidence:

- JSON responses contained complete user records
- No filtering or field restriction applied

Impact:
Increased risk of exposing sensitive or unnecessary information.

Business Explanation:
Providing more data than required increases the attack surface and may violate data privacy principles.

Recommendation:

- Apply data minimization
- Return only required fields

5.3 No Rate Limiting

Observation:
Repeated API requests were processed without restriction.

Evidence:

- Multiple rapid requests captured in Wireshark
- No throttling or blocking observed

Impact:
The API is vulnerable to abuse, including denial-of-service (DoS) attacks and data scraping.

Business Explanation:
Unrestricted access allows attackers to overload systems or extract large volumes of data.

Recommendation:

- Implement rate limiting (e.g., requests per minute)
- Monitor abnormal traffic patterns

5.4 Weak Input Validation (Low Risk)

Observation:
The API accepted arbitrary input without validation.

Evidence:

- POST requests accepted unverified data
- No validation errors returned

Impact:
Potential for injection-based attacks or data inconsistency.

Business Explanation:
Unvalidated input can lead to security vulnerabilities and unreliable data.

Recommendation:

- Validate and sanitize all inputs
- Enforce strict data formats

5.5 Secure Transmission

Observation:
API communication occurs over HTTPS.

Evidence:

- Traffic captured on port 443
- Encrypted communication observed

Impact:
Data is protected from interception during transmission.

Business Explanation:
Encryption ensures confidentiality and protects user data in transit.

Recommendation:

- Maintain HTTPS enforcement

- Implement additional security layers

---

6. Wireshark Traffic Analysis Summary

Network traffic analysis revealed:

- API requests used standard HTTP methods (GET, POST)
- Responses returned structured JSON data
- No authentication headers were present
- Repeated requests showed no rate-limiting behavior

This confirms that **security gaps are visible at both application and network levels**.

---

7. Business Risk Overview

The identified vulnerabilities expose the system to:

- Unauthorized data access
- Data leakage and privacy risks
- Service abuse and potential downtime
- Reduced trust and reputational damage

Even moderate vulnerabilities can escalate when combined, increasing overall risk.

---

8. Recommendations Summary

- Enforce authentication and authorization
- Limit data exposure in API responses
- Implement rate limiting and monitoring
- Validate and sanitize all input data
- Continuously monitor API traffic

---

9. Conclusion

The API demonstrates common security weaknesses typical of non-secured environments. While HTTPS ensures secure transmission, the lack of access control and request limitations presents significant risks.

Addressing these issues will greatly enhance the security posture and resilience of the system.

---

10. Key Learning Outcomes

- Practical API security testing using Postman
- Network traffic analysis using Wireshark
- Risk identification and classification
- Translating technical findings into business impact
- Creating client-ready security reports